

Wireless Security Lab Report

WPA2-PSK Handshake Capture & Dictionary Attack Analysis — Self-Authorized Audit

Analyst	Aadarsh Bonthula
Institution	Manav Rachna International Institute of Research and Studies
Program	B.Tech CSE — Cybersecurity Specialization (2nd Year)
Session Date	24 May 2026
Engagement Type	Self-authorized audit of personally-owned wireless network
Mentor / Reviewer	Claude (Senior Cybersecurity Mentor)
Status	Phase 1 (Capture) — COMPLETE Phase 2 (Crack Benchmark) — DEFERRED

Authorization Statement. All wireless capture and analysis activities documented in this report were performed against a personally-owned access point on a personally-controlled client device, in compliance with the Indian Information Technology Act, 2000 (Sections 43 & 66). No third-party network or device was targeted at any point during this session.

Objective

To gain practical, end-to-end experience in the WPA2-PSK handshake capture workflow using the aircrack-ng suite within a virtualized Kali Linux environment, while practicing forensic discipline (evidence hashing, chain-of-custody, timeline documentation). Secondary objective: build the foundational knowledge required for a future role in wireless forensics investigation within the Police Cyber Crime Unit.

1. Lab Environment

Component	Configuration	Notes
Host OS	Microsoft Windows	Laptop on AC power throughout
Hypervisor	VMware Workstation / Player	USB 2.0 controller (3.x failed)
Guest OS	Kali Linux (VM)	Full aircrack-ng suite preinstalled
Wireless Adapter	Alfa AWUS036ACH (Realtek RTL8812AU)	External USB; passed through via VMware Removable Devices
Target AP	Personally-owned home router (WPA2-PSK)	BSSID/SSID redacted for OPSEC
Target Client	Personally-owned mobile device	STATION MAC redacted
Toolchain	airmon-ng, airodump-ng, aireplay-ng, aircrack-ng	Standard aircrack-ng 1.7 suite

1.1 Pre-Lab Hardware Troubleshooting

Significant pre-lab effort was required to make the wireless adapter visible inside the Kali VM. The root cause was VMware's USB 3.x controller failing to deliver clean power to the Alfa adapter on connection — the adapter LED would not light up when attached to the VM. Resolution involved a systematic diagnostic chain: confirm adapter health on host OS, verify the VMware USB Arbitration Service was running, downgrade USB controller from 3.1 to 2.0, then reconnect the device. After the change, lsusb recognized the Realtek RTL8812AU and iwconfig presented wlan0 in managed mode, ready for monitor-mode promotion.

Lesson Learned. Approximately 60% of beginner failures in wireless labs occur in the USB-passthrough or driver-loading phase, not in the attack chain itself. Always validate the hardware path before running any aircrack-ng commands. The systematic isolation approach used here (host → VM → kernel → driver → interface) is the same pattern applied in production incident response.

2. Methodology — Step-by-Step Execution

Each step was executed and verified before proceeding to the next, following standard forensic discipline. Outputs were observed at every stage; assumptions were not made.

Step 1 — Kill Interfering Processes

```
sudo airmon-ng check kill
```

Terminates NetworkManager, wpa_supplicant, and any process competing for control of the wireless interface. Without this step, the adapter silently reverts from monitor mode or drifts off the locked channel during capture, corrupting handshake reception.

Step 2 — Enable Monitor Mode

```
sudo airmon-ng start wlan0
```

Reconfigures the Alfa adapter to passively receive all 802.11 frames in range. On newer Kali releases, airmon-ng does not rename the interface to wlan0mon; it flips wlan0 in place. Verification via iwconfig confirmed Mode:Monitor.

Step 3 — Broad Reconnaissance

```
sudo airodump-ng wlan0
```

Channel-hopping scan across all 2.4 GHz channels. The target AP's BSSID, channel, encryption (WPA2 CCMP PSK), and one connected STATION were identified. Signal strength (PWR) was strong, indicating reliable subsequent capture.

Step 4 — Locked Targeted Capture

```
sudo airodump-ng -c <CH> --bssid <AP_BSSID> -w handshake wlan0
```

Channel-locked capture filtered to a single AP. Writing to disk in pcap format produced the handshake-01.cap evidence file. The terminal was left running while Step 5 was executed in a parallel terminal.

Step 5 — Deauthentication Attack

```
sudo aireplay-ng --deauth 5 -a <AP_BSSID> -c <CLIENT_MAC> wlan0
```

Five bursts of spoofed deauthentication frames were transmitted, sourced from the AP's MAC and addressed to the target client. The client disconnected and immediately reassociated, triggering a fresh 4-way EAPOL handshake. Because WPA2 management frames are unauthenticated by default (no Protected Management Frames / 802.11w in use), the spoofed deauth was accepted without challenge.

Step 6 — Handshake Verification

```
sudo aircrack-ng handshake-01.cap
```

Output confirmed WPA (1 handshake) against the target BSSID, indicating sufficient EAPOL frames (at minimum M1 + M2 of the 4-way exchange) were captured to support a subsequent offline dictionary attack.

3. Technical Deep-Dive — What Was Actually Observed

3.1 The 4-Way EAPOL Handshake

Frame	Direction	Contents	Required for Cracking?
M1	AP → Client	ANonce (AP's random nonce)	Yes
M2	Client → AP	SNonce + MIC (Message Integrity Code)	Yes (critical)
M3	AP → Client	GTK (group key) + MIC	Bonus
M4	Client → AP	Acknowledgement	Bonus

Aircrack-ng's dictionary attack succeeds because the MIC in M2 is computed as a function of the PMK (Pairwise Master Key, derived deterministically from the WPA2 passphrase via PBKDF2-HMAC-SHA1 with 4096 iterations), the two nonces, and both MAC addresses. The attacker iterates passphrase candidates, derives a candidate PMK, recomputes the MIC, and compares to the captured MIC. A match reveals the passphrase. There is no algorithmic shortcut; the only attack is brute force, which is why strong passphrases and large keyspaces matter.

3.2 airodump-ng Output Anatomy

Column	Meaning	Forensic Relevance
BSSID	AP MAC address	OUI (first 3 octets) identifies vendor; fingerprints physical AP
PWR	Signal strength in dBm (closer to 0 = stronger)	Enables rough physical localization via triangulation
Beacons	Count of beacon frames seen	Anomalies may suggest beacon jamming or stealth APs
#Data	Data frame count	Indicates active client traffic on the AP
CH	802.11 channel number	Determines lock-target for focused capture
ENC / CIPHER / AUTH	WPA2 CCMP PSK confirmed	Determines applicable attack model
STATION	Client MAC address	OUI reveals manufacturer; subject to MAC randomization in modern OSes
Probes	SSIDs the client is searching for	Privacy leak — reveals client's historical Wi-Fi locations
Notes / EAPOL	Indicates captured handshake frames	The win condition for this attack

3.3 Threat Modeling — Defender's Perspective

Because this exercise was self-authorized, the analyst additionally explored the inverse question: how would a defender detect unauthorized clients on their network, and how would an attacker evade that detection? The following threat / evasion / counter matrix emerged from the discussion and is queued as a follow-up project (see Section 6).

Attacker Evasion	Defender Counter
MAC spoofing to mimic legitimate vendor OUI	Whitelist exact MACs (not just vendors); fingerprint via DHCP option order and TTL
MAC randomization per session	Behavioral fingerprinting; probe-request timing analysis
Passive monitor-mode-only sniffing (no association)	WPA2/WPA3 with strong PSK; HTTPS / DNS-over-HTTPS at application layer; physical security
Burst connections at off-hours	Continuous logging via arpwatch / pi-hole / kismet with email or Telegram alerts
VPN tunneling over the Wi-Fi association	Per-device bandwidth monitoring; alert on anomalous outbound volume

Mentor Insight. The discipline of asking *'what does this tool detect / how would an attacker evade it / what is the counter-evasion?'* for every tool learned is the mental model that separates a tool-runner from a security professional. This habit will be applied to every future tool encountered during the Jr Penetration Tester path and beyond.

4. Evidence Artifacts & Chain of Custody

All artifacts produced during the lab are listed below. SHA-256 hashing was performed (or queued for performance) immediately after capture finalization to establish evidence integrity — a baseline requirement for any forensically defensible analysis.

Artifact	Type	Purpose
handshake-01.cap	Raw 802.11 pcap capture	Primary evidence — contains the WPA2 4-way handshake
handshake-01.csv	AP / Station summary	Tabular log of observed APs and stations
handshake-01.kismet.csv	Kismet-format CSV	Cross-tool compatibility log
handshake-01.kismet.netxml	Kismet XML log	Detailed structured log of observed networks
handshake-01.log.csv	GPS log (empty)	No GPS adapter attached
handshake-01.cap.sha256	SHA-256 hash file	Integrity proof for chain of custody

Recommended Chain-of-Custody Entry Template

Evidence file:	handshake-01.cap
Capture timestamp:	2026-05-24 [TIME] IST
Analyst:	Aadarsh Bonthula
Hardware:	Alfa AWUS036ACH (RTL8812AU)
SHA-256:	[insert hash here after running sha256sum]
Location:	Personal residence -- self-owned AP
Authorization:	Self (owner of target AP and client)
Handshake status:	Verified by aircrack-ng (1 handshake)

5. Findings & Observations

#	Finding	Significance
F-1	WPA2-PSK handshake successfully captured against self-owned AP using full aircrack-ng chain.	Confirms operational competence in the standard wireless audit workflow.
F-2	Realtek RTL8812AU driver functioned cleanly in monitor mode after USB controller downgrade to 2.0.	USB 3.x in VMware introduces power negotiation issues with certain bus-powered adapters.
F-3	Spoofed deauthentication succeeded against client without protection.	Confirms target AP does not enforce 802.11w (PMF). PMF would mitigate this attack.
F-4	Channel-locked capture and broadcast-filtered capture produced a clean handshake within 5 deauth bursts.	Standard 5-burst deauth is sufficient for cooperative clients; broadcast deauth is a backup.
F-5	No prior calibration of expected device MAC inventory existed.	A baseline inventory is required for any meaningful defender-side anomaly detection. Queued.

5.1 Defensive Recommendations (Self-Applicable)

Priority	Recommendation
HIGH	Upgrade AP to WPA3-SAE if all client devices support it; SAE eliminates the offline dictionary attack vector entirely.
HIGH	If WPA3 is not viable, enforce a 16+ character random WPA2-PSK passphrase that is absent from public leak corpora (rockyou.txt and equivalents).
MEDIUM	Enable 802.11w (Protected Management Frames) on the AP to mitigate deauth-based handshake forcing.
MEDIUM	Disable WPS (PIN-based) on the AP — the WPS PIN is brute-forceable in hours independent of WPA2 passphrase strength.
MEDIUM	Isolate IoT and smart-home devices onto a separate guest SSID with no LAN access to primary devices.
LOW	Deploy arpwatch or equivalent on a 24/7 monitoring host to alert on new MAC appearances.
LOW	Maintain a documented inventory of all known household MAC addresses for monthly audit comparison.

6. Deferred Work & Queued Follow-Ups

The following items were identified during this session as logical next steps but were deferred to focus on the OSINT platform (TRACE) and other strategic priorities. They are logged here for retrieval in future sessions.

ID	Task	Reason / Context
D-1	Custom wordlist generation experiment — crunch (pattern-based) + cupp (profile-based) — with graduated complexity tiers.	Designed in detail this session. Goal: benchmark how long a targeted wordlist takes to crack a memorable-but-complex passphrase, simulating an OSINT-driven adversary rather than blind rockyou.txt.
D-2	Recapture handshake against a new test passphrase, then run dictionary attack benchmarks across three tiers (crunch, cupp, rockyou).	Requires setting a known test password on the router. Provides quantitative measurement of password-class resistance.
D-3	Home network defense audit — full MAC inventory, nmap sweep, arpwatch deployment, router hardening (WPA3, disable WPS, MAC whitelist, guest SSID for IoT).	Defender-side complement to this offensive exercise. Builds the inventory baseline required for credible anomaly detection.
D-4	Threat-modeling matrix template — applied to airodump-ng first (MAC spoofing, randomization, passive sniffing, burst connections, VPN tunneling), then expanded for every subsequent tool in the Jr Pen Tester path.	Mental model exercise. Becomes a personal reference document over time.
D-5	Acceleration test using hashcat with GPU offload (cloud GPU rental option for benchmark).	Demonstrates realistic attacker speed (100x+ over CPU aircrack-ng). Useful for impact framing in future client deliverables.

7. Legal & Ethical Framing

Critical. The techniques documented in this report are illegal to perform against networks the analyst does not own or have explicit written authorization to test. Under the Indian Information Technology Act, 2000 — Section 43 (penalty for damage to computer/computer system) and Section 66 (computer-related offences) — unauthorized access to a computer network is punishable by fines up to INR 1 crore and/or imprisonment up to three years. The 'it was just a lab' framing offers no legal defense.

The analyst is preparing for a future role within the Police Cyber Crime Unit as a Forensic Investigator. Maintaining a clean operational record is a non-negotiable prerequisite for that path. All offensive techniques learned during academic and self-study phases must remain confined to:

- (a) Networks and devices the analyst personally owns;
- (b) Sanctioned lab environments such as TryHackMe, Hack The Box, or institution-provided ranges;
- (c) Engagements with written authorization (signed Rules of Engagement / Statement of Work).

8. Conclusion

This session represents a complete end-to-end execution of the WPA2 handshake capture phase of a wireless security audit, conducted with appropriate ethical scope and forensic discipline. The analyst demonstrated effective troubleshooting of a non-trivial USB-passthrough hardware issue, correct sequencing of the airon-ng / airodump-ng / aireplay-ng / aircrack-ng toolchain, and — most importantly — the instinct to verify state at every checkpoint rather than proceeding on assumptions.

The follow-on phase (custom wordlist generation and dictionary attack benchmarking) is deferred to a future session. The foundation laid here will also feed directly into the TRACE OSINT tool roadmap, where understanding of attacker workflows informs the design of investigative tooling for law enforcement.

Next Step. Commit this report to the analyst's GitHub portfolio (private repository, or a sanitized public version) as evidence of structured, ethical wireless security competence. When the TRACE OSINT tool's MVP is published, this report can be referenced as supporting context demonstrating the analyst's hands-on understanding of the attacker mindset.